DOCUMENTO DE TRABAJO • COMITÉ DE PREVENCIÓN DE FRAUDE

Consorcio Federal Antifraude: Minuta Ejecutiva y Estado del Sistema

Destinataria: Gerencia de Prevención de Fraude & CISO **Plataforma:** antifraude-one.vercel.app **Fecha:** Octubre 2026

Nivel de Acceso: Confidencial / Bancario

A ¿Qué hace hoy el sistema? (Explicación para Negocio)

El sistema funciona como una **red interbancaria de alerta temprana y defensa cruzada** entre entidades financieras (Bancos, Billeteras Virtuales y PSPs). Su misión principal es detectar y bloquear transferencias hacia cuentas puente ("mulas"), usurpaciones de identidad y bandas organizadas **en tiempo real (<15ms)**, antes de que el dinero sea retirado del circuito bancario.

1. Datos Analizados con Privacidad Absoluta (Secreto Bancario & Ley 25.326):

El consorcio **nunca almacena ni transmite datos personales en texto claro**. Cada identificador (CBU/CVU de 22 dígitos con Módulo 10 BCRA, CUIT/CUIL con Módulo 11 AFIP, DNI, Email, Teléfono, IP y Huella Digital de Dispositivo) es transformado en origen en un **Token Ciego Irreversible (HMAC-SHA256 con Pepper custodiado en KMS y Separación de Dominio)**. Dos bancos pueden comprobar si comparten un atacante sin relevar la identidad de sus clientes.

```
Token = HMAC_SHA256( Normalizar(Identificador) , Pepper_Secreto_KMS_256bits )
```

2. Cómo se calcula el Score de Riesgo (0 a 100):

El motor pondera automáticamente 5 dimensiones matemáticas:

- **Severidad del Antecedente:** Cuenta Mula confirmada (90 pts base), Fraude (95 pts), Robo Identidad (80 pts), Phishing (60 pts).
- **Efecto Red Multientidad:** Si un mismo DNI/CBU/Dispositivo aparece en 2 bancos el score se multiplica por **1.25x**; en 3 bancos por **1.50x**; y en 4 o más entidades por **1.80x**.
- **Piso Crítico por Granja de Dispositivos:** Si un mismo teléfono/navegador se detecta operando con 3 o más CUITs distintos en poco tiempo, se impone un **piso automático de 85 puntos**.
- **Inteligencia de Email:** Penaliza emails de dominios temporales/descartables (+40 pts) o dominios sin registro MX (+35 pts).
- **Decaimiento Temporal (180 días):** Las incidencias pierden peso logarítmicamente mes a mes si el titular no reincide.

3. Decisiones y Recomendaciones Operativas:

BAJO RIESGO

0 - 34 pts

APROBAR: Transacción legítima aprobada sin fricción. Sin anomalías en red.

RIESGO MEDIO

35 - 74 pts

REVISIÓN / FRICCIÓN: Desafío 2FA biométrico obligatorio o diferimiento de acreditación por 2hs.

RIESGO CRÍTICO

75 - 100 pts

BLOQUEO AUTOMÁTICO: Rechazo de transferencia, congelamiento preventivo y alerta federal.

B Funcionalidades Actuales y Estado de Madurez

1. Portal Empresa / Bancos Participantes (`#partner-portal` / `/bancos`)

FUNCIONALIDAD	DESCRIPCIÓN OPERATIVA	ESTADO
Consulta de Riesgo Individual	Búsqueda por DNI, CBU/CVU, Email, Teléfono o Device con autodetección de campo y validación sintáctica BCRA/AFIP.	FUNCIONA
Separación Visual de Riesgo	Pantalla dividida en 2 columnas paralelas: *Riesgo Propio* (antecedentes internos) vs *Riesgo en Red* (consorcio).	FUNCIONA
Reporte en 2 Pasos	Previsualización con tokens ciegos generados antes de confirmar la carga de fraude en el consorcio.	FUNCIONA
Desmarque Inmediato	Botón post-reporte para retirar o rectificar voluntariamente un reporte erróneo en tiempo real.	FUNCIONA
Dashboard y Tasa Crítica	Tarjetas de KPIs calculadas sobre el día actual (Aprobadas/Revisión/Rechazadas) con tasa acotada [0-100%].	FUNCIONA
Evaluación Masiva CSV	Carga de lotes de transferencias para scoring en cliente.	PARCIAL

2. Portal de Gobernanza Central / Consorcio (`#admin-portal` / `/admin`)

FUNCIONALIDAD	DESCRIPCIÓN OPERATIVA	ESTADO
Segundo Factor (2FA TOTP)	Google Authenticator / Authy obligatorio con almacenamiento persistente en Supabase (cero reseteos en actualizaciones).	FUNCIONA
Gestión y Cuarentena	Monitoreo de bancos miembros y botón de suspensión administrativa inmediata por WebSockets.	FUNCIONA
Laboratorio de Calibración	Ajuste dinámico de umbrales críticos y pesos de scoring guardados en base de datos.	FUNCIONA
Auditoría Inmutable	Trazabilidad de cada consulta y reporte con marca temporal, actor y motivo para auditorías BCRA.	FUNCIONA
Explorador de Grafos (3 Saltos)	Visualización de redes de mulas interconectadas.	PARCIAL (>10K NODOS)

C Limitaciones y Riesgos Detectados

1. Seguridad y Criptografía:
El Pepper secreto para blind indexing actualmente está en variables de entorno seguras. Para producción bancaria debe residir en un **HSM FIPS 140-2 (AWS CloudHSM / Azure Managed HSM)** con rotación periódica.

2. Calibración con Datos Reales:
Hoy el consorcio opera con incidentes de validación. Es fundamental realizar un piloto con **lotes históricos reales anonimizados** provistos por bancos socios para calibrar falsos positivos antes de ir a producción.

3. Marco Legal y Habeas Data:
Se requiere instrumentar el **Convenio de Adhesión Interbancario de Co-Responsabilidad (Ley 25.326)** y un protocolo formal de rectificación judicial cuando un cliente demuestre ser víctima de usurpación.

4. Escalabilidad en Picos Masivos:
La latencia actual a Supabase es óptima (11-14ms). Para volúmenes de compensación nacional masiva (500 tx/seg) se requerirán réplicas de lectura en Edge con caché Redis/Dragonfly.

D Puntos de Mejora Priorizados

PRIORIDAD	INICIATIVA / MEJORA	JUSTIFICACIÓN TÉCNICA Y OPERATIVA	ESFUERZO
ALTA	**Conexión a HSM / KMS Bancario**	Custodia de clave Pepper de Blind Indexing en bóveda física o HSM en nube. Excluyente para CISO.	2 semanas
ALTA	**API Asíncrona de Consulta Masiva**	Endpoint backend para que los motores centrales de los bancos consulten en <20ms por webhook.	1.5 semanas
ALTA	**Protocolo de Desmarque Judicial**	Flujo formal de remediación para sobreseídos o víctimas de usurpación con auditoría pericial.	1 semana
MEDIA	**Optimización del Visor de Grafos**	Paginación y renderizado virtual para clústeres de más de 20.000 vínculos simultáneos.	1.5 semanas
MEDIA	**Integración con Denuncias UFECI**	Ingesta tokenizada de denuncias penales del Ministerio Público Fiscal para enriquecer la blacklist.	2 semanas
BAJA	**Certificados Periciales en PDF**	Exportación de informes con firma hash SHA-256 para presentación directa en juzgados o fiscalías.	1 semana

E Preguntas Clave para la Experta en Fraude (Guía de Entrevista)

Utilizar estas preguntas directas durante la reunión para consensuar las reglas de negocio bancarias:

1. Señales y Patrones Críticos de Fraude

- ¿Cuáles son hoy los 3 patrones de fraude de mayor crecimiento y pérdida en su entidad (toma de home banking por vishing, apertura masiva de cuentas mulas remuneradas, préstamos preconcedidos express)?
- ¿Qué atributo consideran más predictivo de una cuenta mula: el CBU/CVU de destino o la huella de dispositivo compartido (Device Fingerprint)?

2. Validación de "Fraude" vs. "Sospecha Fundada"

- ¿Qué estándar probatorio interno exige el banco antes de marcar un CBU en el consorcio (denuncia policial del cliente, pericia forense, o basta la confirmación de la víctima)?
- ¿Qué metadatos adicionales consideran indispensables compartir (hora exacta, monto involucrado, canal APP/Web)?

3. Tolerancia Operativa a Falsos Positivos vs. Falsos Negativos

- En transferencias inmediatas (Transferencias 3.0), ¿cuál es la tasa máxima de falsos positivos que su centro de atención puede tolerar antes de que el costo de soporte supere las pérdidas por fraude?
- ¿Prefieren un modelo con alto recall (detectar todo indicio con más revisión manual) o alta precisión (bloquear solo ante certeza)?

4. Bloqueo Automático vs. Fricción Dinámica

- En operaciones críticas (>75 pts), ¿su entidad autorizaría el rechazo automático de la transferencia saliente o prefieren forzar un desafío biométrico facial del titular y diferir la acreditación 2 horas?

5. Regulación, Privacidad (Ley 25.326) y Prueba Piloto

- ¿Cómo evalúa el área de Legales y Compliance el uso de Blind Indexing (HMAC con Pepper KMS) donde el consorcio no custodia datos personales?
- ¿Estarían dispuestos a compartir un lote histórico de 500 cuentas de fraude cerrado (tokenizadas ciegamente) para calibrar el algoritmo antes de la integración en vivo?

F Propuesta de Próximos Pasos y Roadmap en 3 Etapas

ETAPA 1: Calibración Heurística y Ajuste de Privacidad Bancaria

Semanas 1 a 4

- Concluir la mesa de trabajo con la especialista en fraude para ajustar pesos del scoring según tipologías locales.
- Implementar la custodia de la clave Pepper en HSM Cloud (AWS CloudHSM o Azure Key Vault) con Blind Indexing FIPS 140-2.
- Ejecutar pruebas con lote histórico tokenizado ciegamente provisto por los bancos para medir y acotar falsos positivos.

Entregables: *Matriz de scoring calibrada, reporte de no-falsos positivos y dictamen de cumplimiento Ley 25.326.*

ETAPA 2: Piloto Técnico Controlado en Red Privada (3 Entidades)

Semanas 5 a 9

- Conexión de 3 entidades financieras en sandbox seguro interbancario mediante API Gateway con autenticación mTLS.
- Simulación de ataques coordinados: inyección de cuentas mulas en un banco y verificación de alerta en <20ms en los otros dos.
- Medición del impacto operativo en la cola de trabajo de los analistas de fraude.

Entregables: *Certificado de latencia en estrés (<25ms p99) y reporte de intercepción multientidad.*

ETAPA 3: Homologación Regulatoria y Producción Federal

Semanas 10 a 16

- Presentación formal ante mesas de ciberseguridad del BCRA (cumplimiento Comunicaciones "A" 7724 y 6835).
- Firma del Convenio Federal de Gobernanza y Confidencialidad entre bancos fundadores.
- Despliegue de infraestructura productiva multizona con monitoreo 24/7 y apertura para la adhesión de nuevas entidades.

Entregables: *Plataforma en producción, consorcio operativo formal y tablero federal activo.*

Plataforma disponible para demostración en vivo durante la reunión:
https://antifraude-one.vercel.app (Acceso: Portal Bancos / Gobernanza con 2FA activo)